

FREE MOBILE data breach action

[Association], a certified consumer association, seeks €[to be set] to fund a French collective damages action (action de groupe) against FREE MOBILE on behalf of 24,633,469 victims (counted as contracts by the CNIL).

Source decision: CNIL Délibération SAN-2026-001 du 8 janvier 2026

Legal basis: GDPR art. 5-1-e, GDPR art. 32, GDPR art. 34

Status: appeal status not stated in the decision

DRAFT FOR LEGAL REVIEW · generated from the CNIL decision · every quote is checked word for word against the decision · values in [brackets] are to be provided

Type of harm

IS THE HARM QUANTIFIED?

☐ Quantified ☐ Quantifiable ☒ To be proven

NATURE

☒ Financial ☒ Non-material ☐ Overcharge ☐ Loss of chance

The decision recognises a risk of financial harm (e.g., fraudulent payments using exposed IBANs) and non-material harm (e.g., distress, fear of identity theft, phishing attempts) for the affected individuals due to the data breach.

« la formation restreinte considère que l'accès non autorisé ou la divulgation des données traitées par la société est de nature à créer un préjudice moral et matériel pour les personnes concernées. » (p. 11) ✓ **verbatim**

Victims

NUMBER CNIL decision

24,633,469

contracts

IDENTIFIABLE?

☒ Yes ☐ Partly ☐ No

« l'attaquant a pu prendre connaissance, des données concernant 24 633 469 contrats » (p. 3) ✓ **verbatim**

CATEGORY

☒ Consumers ☐ Businesses ☐ Retail investors ☐ Employees

☐ Other

Proof of class membership: the breach notification email sent between 24 and 29 October 2024

Subgroups: customers whose IBAN was exposed (convergent customers); customers whose identity, contact, and contractual data were exposed

« a informé les personnes concernées de la survenance de la violation de données, par courriel, de manière échelonnée entre le 24 et le 29 octobre 2024 » (p. 2) ✓ **verbatim** · repaired by code, check support

Defendant

NATURE

☒ Private company ☐ Listed group ☐ Public body
☐ Association or union

SOLVENCY

☐ Low ☐ Medium ☒ Strong

The parent group ILIAD had a revenue of 10.024 billion euros in 2024.

Indicators: revenue €10.0bn (ILIAD, 2024), group ILIAD, insurance [], competent court civil **Assumption**

« En 2024, le chiffre d'affaires de la société ILIAD était de 10,024 milliards d'euros pour un résultat net de 367 millions d'euros. » (p. 2) ✓ **verbatim**

Value of the claim

Total = victims who opt in × compensation per victim **Computed**

CATEGORY OF HARM (OPT-IN TABLE)

Violation de données par défaut de sécurité, victimes identifiées

« l'attaquant a pu prendre connaissance, des données concernant 24 633 469 contrats, » (p. 3) ✓ **verbatim** · repaired by code, check support

Scenario	Opt-ins	€ / victim	Total
Low (1.4%)	344,869	€150	€51.7M
Base (4%)	985,339	€150	€147.8M
High (15%)	3,695,020	€150	€554.3M

EXPECTED OPT-IN

6.8%

± 2.95 pts · past cases in this category

FUNDER'S SHARE

30%

€44.3M at base scenario

Opt-in rates from the legal team's table of past cases; €150 per victim; each of the contracts counted by the CNIL is treated as one person. Benchmarks: minimum claim of €2-4M in France; investment of about 1/10 of claim value (European Commission study, 2025).

Timeline

Expected duration: [] years · Limitation period ends: [date]

Facts	Source decision	Filing	Judgment on liability	Victims opt in	Compensation paid
Sept.–Oct. 2024	8 Jan. 2026	[target date]	[estimate]	[period]	[estimate]

« Celle-ci a duré du 28 septembre au 22 octobre 2024. » (p. 2) ✓ **verbatim**

FUNDING FRAMEWORK · ART. 16, FRENCH LAW OF 30 APRIL 2025

- ☐ No funder influence over the conduct of the action
- ☐ Funding publicly disclosed
- ☐ Written conflict-of-interest policy
- ☐ Funder has no ties to the defendant

Ticked only by the association.

THE ASSOCIATION

[Name], certified since [date]
Statutory purpose: [link to the action]
Counsel: [law firm]
Contact: [name, role, email]

Summary of the decision

Délibération SAN-2026-001 du 8 janvier 2026. Every fact cites the paragraph (§) of the decision; each citation was checked against the decision text by code (△ = could not be verified).

0. Identification

The decision is **SAN-2026-001** of **8 January 2026** by the *formation restreinte* of the **CNIL** (Commission Nationale de l'Informatique et des Libertés) (header). It is a **penalty decision** imposing a fine, an injunction with a periodic penalty (*astreinte*), and publication (operative part). The organisation is **Free Mobile**, a mobile operator owned by the **Iliad group**; its name is **not redacted** (§ 1). The decision is **public with redactions** for personal data and legally protected secrets (header). Appeal is possible; deadline **to be checked by the tool** (operative part).

One-sentence summary: the CNIL fines **Free Mobile €27,000,000** for breaching **GDPR Articles 5-1-e) (excessive retention), 32 (security) and 34 (notification to data subjects)** after a **data breach affecting 24,633,469 contracts** (operative part).

1. Facts

Who

The sanctioned organisation is **Free Mobile**, a **mobile operator** belonging to the **Iliad group**; Iliad is the parent company and holds **100 %** of Free Mobile (§ 1). The **Iliad group** had **more than 50.2 million subscribers** in 2024; **Free Mobile** alone had **about 15.5 million mobile subscribers** as of **31 December 2024** (§ 1). Iliad's **2024 revenue** was **€10.024 billion** with a **net profit of €367 million** (§ 1). The case originated from a **data breach notification** by Free Mobile (§ 3). The **CNIL had received 2,614 complaints** from affected individuals by the date the sanction report was notified (§ 4).

What

The processing at issue is the **management of subscriber contracts** via the **MOBO customer management tool** (§ 19). The **data concerned** include **identity data, contact data, contractual data, and, for "convergent" customers (mobile and fixed-line), IBANs** (§ 20 △). The **attacker accessed data on 24,633,469 contracts**, of which **19,460,891 were mobile (Free Mobile) and 5,172,577 were fixed-line (Free)**: "l'attaquant a pu prendre connaissance des données concernant 24 633 469 contrats" (§ 21). The breach lasted from **28 September to 22 October 2024** (§ 2).

The *formation restreinte* holds that the disclosure "**est de nature à créer un préjudice moral et matériel**" [is likely to cause non-material and material harm], citing **identity theft, phishing and fraudulent payments with a stolen IBAN** (§ 82). However, the CNIL admits it is "**pas possible de déterminer avec certitude**" [not possible to determine with certainty] that the frauds reported by complainants come from this breach (§ 84). The decision does not state any earlier penalties or formal notices against Free Mobile.

Where

The territory is **France**. The CNIL acted as the **lead authority**; no one-stop-shop cooperation is mentioned (header △).

When

The **breach period** was **28 September to 22 October 2024** (§ 2). Free Mobile **discovered the incident on 21 October 2024** via an alert from the attacker (§ 2). It **notified the CNIL on 23 October 2024** and **completed the notification on 5 November 2024** (§ 3). It **informed data subjects by email between 24 and 29 October 2024** (§ 3). The **on-site inspection** took place on **8 November 2024** (§ 6). The **rapporteur was appointed on 17 February 2025** (§ 7). The **sanction report was notified on 25 July 2025** (§ 9). The **hearing before the restricted committee** was held on **15 December 2025** (§ 15). The **decision was adopted on 8 January 2026** (header △).

2. Procedure

The case began with Free Mobile's **data breach notification** to the CNIL on **23 October 2024** (§ 3). The **CNIL President ordered an on-site inspection on 6 November 2024** (§ 5 △). The **inspection took place on 8 November 2024** at Free Mobile and Free's premises (§ 6). The **CNIL President decided on 24 July 2025 to split the sanction procedure** initially targeting both Free Mobile and Free into two separate procedures (§ 8). The **rapporteur notified the sanction report to Free Mobile on 25 July 2025**, alleging breaches of **Articles 5-1-e), 32 and 34 GDPR** and proposing a fine, an injunction with a periodic penalty, and publication (§ 9). Free Mobile **submitted written observations on 15 September 2025 and 17 November 2025** (§ 10, 12 △). The **rapporteur replied on 15 October 2025** (§ 11 △). The **instruction was closed on 18 November 2025** (§ 13). Free Mobile **requested a postponement of the hearing**, which was granted; the hearing was rescheduled to **15 December 2025** (§ 15). Free Mobile **requested a closed session (huis-clos)**, which was **refused on 3 December 2025** (§ 16). **Oral observations** were presented during the hearing (§ 17). Free Mobile **submitted a note in deliberation on 19 December 2025** (§ 17 △).

The decision **does not mention any parallel criminal or other administrative proceedings**.

3. Legal basis

The *formation restreinte* establishes **three breaches**:

- **Article 5-1-e) GDPR** (excessive retention of personal data) (§ 52).
- **Article 32 GDPR** (failure to implement appropriate technical and organisational security measures) (§ 151).
- **Article 34 GDPR** (failure to communicate the personal data breach to data subjects in a complete manner) (§ 199).

The decision **does not reject any breach** as unfounded.

4. Arguments

The company argues that **the rapporteur wrongly attributes the same breaches to both Free Mobile and Free** without considering their respective responsibilities (§ 24). The *formation restreinte* holds that **each company is responsible for its own processing** and that the **procedures were split**, so the argument is **rejected** (§ 26).

The company argues that **Article 32 GDPR is an obligation of means, not result**, and that the **occurrence of a data breach alone does not establish a breach** (§ 56). The *formation restreinte* **accepts this legal qualification** but holds that **the breach is established because the security measures were insufficient** and facilitated the attack (§ 58).

The company argues that **the principle of legality (*légalité des délits et des peines*) is violated** because Article 32 GDPR and CNIL/ANSSI recommendations are not prescriptive (§ 57). The *formation restreinte* **rejects this argument**, citing **CJEU case law** and **French administrative law**, and holds that **recommendations clarify obligations** and that the **elements of the breach are defined precisely** (§ 65).

The company argues that **the treatment does not present a high risk** because it does not process **special-category data (Article 9 GDPR)** (§ 74). The *formation restreinte* holds that **the risk is high** due to the **massive volume of data (24,633,469 contracts)**, the **sensitive nature of certain data (IBANs)**, and the **potential for identity theft, phishing, and fraudulent payments** (§ 73).

The company argues that **IBAN alone cannot enable fraudulent direct debits** and that **banks have safeguards** (§ 75). The *formation restreinte* holds that **IBANs can be used for fraudulent payments** on websites that validate SEPA mandates via a simple checkbox, and that **the risk of phishing and identity theft is high** (§ 82).

The company argues that **it could not anticipate all future forms of exploitation** of the breach and that **its notification email was sufficient** (§ 174). The *formation restreinte* holds that **the email lacked essential information** (description of remediation measures, probable consequences, and measures data subjects should take) and that **a two-tier communication (email + helpline) does not replace the obligation to include essential information in the first-tier notification** (§ 188-199 △).

The company argues that **the fine is disproportionate** and that **publication would harm its security** (§ 239). The *formation restreinte* **rejects these arguments**, citing the **gravity of the breaches, the number of affected individuals, and the need for deterrence** (§ 240).

The company argues that **the principle *non bis in idem* is violated** because the same facts are sanctioned twice (for Free Mobile and Free) (§ 209). The *formation restreinte* holds that **the procedures are distinct, the companies are separate legal entities, and the breaches are different**, so the principle is **not violated** (§ 213).

Remaining weak points. The CNIL **admits uncertainty** about whether the **excessive retention (Article 5-1-e)) aggravated the security breach (Article 32)**: "les éléments du dossier portés à sa connaissance ne lui permettent pas de se prononcer sur le point de savoir si l'absence d'implémentation de la politique de durée de conservation des données a ou non permis à l'attaquant d'accéder à une profondeur historique de données plus importante," [the elements of the file do not allow it to determine whether the failure to implement the data retention policy allowed the attacker to access a greater historical depth of data] (§ 214). The CNIL also **cannot confirm with certainty** that the frauds reported by complainants stem from this breach (§ 84).

5. Decision

The *formation restreinte* imposes a **fine of €27,000,000** for the breaches of **Articles 5-1-e), 32 and 34 GDPR** (operative part △). The fine is calculated based on the **Iliad group's 2024 revenue (€10.024 billion)**, as Free Mobile and Iliad form a **single economic unit** under EU competition law (§ 244). The **criteria under Article 83 GDPR** considered include:

- **Gravity:** the breaches affected **24,633,469 contracts** and **15 million former subscribers' data were retained excessively**; the **security failures facilitated the breach**; the **notification to data subjects was incomplete** (§ 222).
- **Negligence:** Free Mobile **failed to implement retention policies and security measures** despite having the **resources to do so** (§ 228).
- **Number of affected individuals:** **24,633,469 contracts** were affected by the breach; **only 58,239 individuals called the helpline** (§ 224).
- **Mitigating factors:** Free Mobile **took remediation measures during the procedure**, but **not all were completed by the hearing date** (§ 233).

The *formation restreinte* **does not impose an injunction for Article 34 GDPR** but **orders Free Mobile to comply with Articles 5-1-e) and 32 GDPR** within:

- **6 months for Article 5-1-e):** implement the **data retention policy** by **purging data from contracts terminated for over 10 years** and **retaining only data strictly necessary for accounting purposes for 10 years** (operative part, 2nd indent).
- **3 months for Article 32 GDPR:** implement **appropriate technical and organisational security measures** (operative part, 2nd indent).

The injunction is **assorted with a periodic penalty (*astreinte*) of €50,000 per day of delay**, payable after the **6-month and 3-month deadlines** respectively (operative part, 3rd indent).

The decision **will be published on the CNIL's website and Légifrance** and **will be anonymised after 2 years** (operative part, 4th indent △).

6. Appeal

The decision **can be appealed before the Conseil d'État** (operative part). The **deadline is to be checked by the tool**. The decision **does not mention whether an appeal has been lodged**.